

CSA5107-CRYPTOGRAPHY AND ITS NETWORK SECURITY

ASSIGNMENT

SUBMITTED BY

Mohan Kumar J (192424060)

COMPREHENSIVE ENTERPRISE NETWORK SECURITY ARCHITECTURE

PROBLEM STATEMENT AND PROBLEM FORMULATION

Problem Statement

A multinational organization operates a distributed digital infrastructure consisting of web applications, enterprise servers, email systems, remote users, branch offices, and external business partners. The organization exchanges confidential business information through public and private networks and has recently identified several security concerns, including packet interception, man-in-the-middle attacks, IP spoofing, unauthorized access, email-based attacks, malware propagation, data modification, and denial-of-service attacks.

The existing security infrastructure uses isolated security mechanisms without a unified security architecture. As a result, the organization requires a comprehensive, layered, and scalable network security solution that can protect data, authenticate users and systems, secure network communication, and detect and respond to malicious activities.

Assignment Question

As a Network Security Architect, design and evaluate a comprehensive enterprise network security architecture for the organization. Analyze the security requirements of web, IP, email, and enterprise services and select appropriate security mechanisms to address the identified threats. Your proposed architecture should incorporate appropriate combinations of cryptographic hash algorithms, digital signatures, Kerberos, X.509 certificates, IPsec, SSL/TLS, PGP, S/MIME, firewalls, access-control mechanisms, IDS/IPS, and malware protection techniques.

Evaluate and justify the effectiveness of the proposed architecture against suitable attack scenarios such as man-in-the-middle attacks, IP spoofing, packet sniffing, phishing, unauthorized access, malware propagation, data tampering, and denial-of-service attacks.

Finally, compare the proposed security mechanisms based on confidentiality, integrity, authentication, non-repudiation, availability, performance, scalability, resilience, and manageability, and recommend the most suitable security controls for establishing a secure, reliable, and trusted enterprise communication infrastructure.

COMPREHENSIVE ENTERPRISE NETWORK SECURITY ARCHITECTURE

1. Problem Statement and Problem Formulation

1.1 Problem Statement

A multinational organization operates a distributed digital infrastructure consisting of web applications, enterprise servers, email systems, remote users, branch offices and external business partners. The organization exchanges confidential business information through both public and private networks. Because these systems communicate across different locations and network boundaries, they are exposed to several security threats such as packet interception, man-in-the-middle attacks, IP spoofing, unauthorized access, phishing, malware propagation, data modification and denial-of-service attacks.

The existing security infrastructure uses isolated security mechanisms that protect individual systems but do not provide a unified enterprise-wide security architecture. This creates security gaps between network segments, applications, users, servers and external communication channels. A successful attack against one component may therefore affect other systems if adequate segmentation, authentication, monitoring and access control are not implemented.

The organization therefore requires a comprehensive, layered and scalable network security architecture based on the principle of defence in depth. The proposed architecture combines cryptographic hash algorithms, digital signatures, Kerberos, X.509 certificates, IPsec, SSL/TLS, PGP, S/MIME, firewalls, access-control mechanisms, IDS/IPS and malware protection. These mechanisms work together to provide confidentiality, integrity, authentication, authorization, non-repudiation and availability.

1.2 Problem Formulation

The problem can be formulated as follows:

“How can a multinational organization design and implement a unified, layered and scalable network security architecture that protects web applications, enterprise servers, email systems, remote users, branch offices and external partners against network-based

and application-based attacks while providing confidentiality, integrity, authentication, authorization, non-repudiation and availability?”

The proposed solution must not depend on a single security mechanism. Instead, security must be provided at multiple levels. TLS can secure web and application communication, IPsec can secure network-layer communication, Kerberos can provide centralized authentication, X.509 certificates can establish trusted identities, digital signatures can provide integrity and non-repudiation, while firewalls, IDS/IPS, access controls and malware protection can prevent and detect malicious activities.

2. Objective and Expected Outcomes

2.1 Objectives

- To design a comprehensive enterprise network security architecture based on defence-in-depth principles.
- To protect confidential organizational information from unauthorized disclosure.
- To provide strong authentication for users, servers and network devices.
- To protect web applications using SSL/TLS and X.509 certificates.
- To secure communication between branch offices using IPsec VPN.
- To provide secure remote access for authorized employees.
- To use cryptographic hash algorithms for data-integrity verification.
- To use digital signatures for authentication, integrity and non-repudiation.
- To implement Kerberos for centralized enterprise authentication.
- To use PGP and S/MIME for secure email communication.
- To implement firewalls for controlling incoming and outgoing network traffic.
- To implement access-control mechanisms based on least privilege and user roles.
- To deploy IDS/IPS for detecting and preventing malicious network activity.
- To implement malware protection for servers, endpoints and email attachments.
- To reduce the risk of man-in-the-middle attacks.
- To reduce the risk of IP spoofing and packet sniffing.

- To protect enterprise resources from unauthorized access.
- To reduce phishing and email-based security threats.
- To limit malware propagation between network segments.
- To detect unauthorized data modification.
- To improve network availability against denial-of-service attacks.
- To provide centralized security monitoring and logging.
- To design a scalable architecture suitable for a multinational organization.
- To evaluate the proposed architecture against realistic security attack scenarios.
- To compare the selected mechanisms based on security, performance, scalability, resilience and manageability.

2.2 Expected Outcomes

The expected outcome is a secure enterprise infrastructure in which sensitive organizational information is protected during storage and transmission. Authorized users should be able to access enterprise services securely from headquarters, branch offices and remote locations, while unauthorized users and malicious traffic should be blocked.

The architecture is also expected to provide secure web communication, protected email communication, authenticated enterprise services, encrypted branch connectivity, controlled network access and continuous security monitoring. If one security layer is bypassed, other layers should continue protecting the organization.

3. Requirements, Constraints and Assumptions

3.1 Requirements

The organization requires confidentiality so that sensitive business information cannot be read by unauthorized parties. It requires integrity so that unauthorized modification of information can be detected. Authentication is required to verify the identity of users, servers and devices before communication or access is permitted.

Authorization is also required because authentication alone does not determine what an authenticated user is allowed to access. Therefore, role-based access control, access-control lists and least-privilege principles should be implemented.

The organization additionally requires non-repudiation for important transactions and communications. Digital signatures can provide evidence that a message or document originated from a particular private key holder and was not modified after signing.

Availability is another major requirement because web applications, email systems and enterprise services must remain operational. Redundant infrastructure, load balancing, DDoS protection, backup systems and disaster recovery mechanisms should therefore be incorporated.

The security infrastructure should also support centralized monitoring, logging and incident response. All major security devices should send relevant events to a centralized security monitoring platform.

3.2 Constraints

The organization may have to support legacy applications that do not support modern security protocols. Upgrading such systems may require additional cost and downtime. Security controls such as encryption, deep packet inspection and IDS/IPS can also introduce processing overhead and latency.

Another constraint is the geographical distribution of the organization. Different branch offices may have different network capabilities and Internet connections. Managing certificates, VPN credentials, firewall rules, user accounts and security policies across multiple locations can therefore become complex.

The organization must also consider implementation and operational costs. A complete security architecture requires investment in firewalls, VPN gateways, endpoint protection, monitoring systems, skilled security personnel and regular maintenance.

3.3 Assumptions

It is assumed that the organization has centralized identity management and maintains dedicated servers for critical business applications. It is also assumed that branch offices have secure network connections and that remote employees use organization-managed devices.

It is assumed that public-facing applications can be separated from internal systems using a DMZ. Critical databases and enterprise servers are assumed to be located in protected internal network segments. It is also assumed that the organization performs regular backups, applies security patches and maintains security policies.

4. Application of Relevant Course Knowledge / Concepts

The proposed architecture applies major concepts from network and information security.

4.1 Cryptographic Hash Algorithms

A cryptographic hash function converts data of arbitrary length into a fixed-length digest. The digest acts like a fingerprint of the original data. If the original information is modified, even slightly, the resulting hash value will normally change.

SHA-256 and SHA-384 are appropriate choices for modern integrity applications. Hashing can be used for file integrity verification, digital signatures and message authentication mechanisms. It is important to distinguish general hash functions from password-storage algorithms; passwords should use dedicated password-hashing schemes rather than plain SHA-256.

For example:

Original Data → SHA-256 → Hash Value

After modification:

Modified Data → SHA-256 → Different Hash Value

The difference indicates that the data has been changed.

4.2 Digital Signatures

A digital signature uses asymmetric cryptography to prove the origin and integrity of information. The sender generates a digest of the message and signs it using a private key. The receiver uses the corresponding public key to verify the signature.

Digital signatures provide authentication, integrity and non-repudiation. They are especially useful for sensitive business documents, financial transactions, software packages and signed email.

The process is:

Message → Hash → Private Key → Digital Signature

At the receiving side:

Message + Signature + Public Key → Verification

If verification fails, the receiver knows that the message may have been modified or that the signature is not valid for the claimed signer.

4.3 Kerberos

Kerberos is a centralized network authentication protocol that uses tickets instead of repeatedly sending passwords across the network. It is particularly suitable for internal enterprise environments.

The main components are the Authentication Server, Ticket Granting Server and service servers. Together, these components form the basis of a Key Distribution Center.

A simplified process is:

User → Authentication Server → Ticket Granting Ticket → TGS → Service Ticket → Enterprise Server

After successful authentication, the user receives a ticket that can be used to access authorized enterprise services. Kerberos is therefore suitable for centralized enterprise authentication, file servers, internal applications and directory-based environments.

4.4 X.509 Certificates

X.509 certificates associate an identity with a public key and are normally issued by a trusted Certificate Authority. Certificates are essential for establishing trust in TLS connections.

An X.509 certificate contains information such as the subject identity, public key, issuer, validity period, serial number, key usage and the CA's digital signature.

In the proposed architecture, certificates are used for web servers, VPN gateways, selected clients, secure email and other certificate-based services.

4.5 IPsec

IPsec provides security at the IP/network layer. It is especially useful when communication must be protected between two network locations.

The proposed architecture uses IPsec for branch-to-headquarters and branch-to-branch VPN connections. Remote users may also use an organization-approved secure VPN solution.

IPsec protects communication by providing encryption, integrity and authentication. IKEv2 can be used to establish security associations and negotiate cryptographic parameters.

The basic communication path is:

Branch Office → IPsec VPN Tunnel → Headquarters VPN Gateway → Internal Network

This protects sensitive traffic from interception while travelling across untrusted networks.

4.6 SSL/TLS

TLS protects application-level communication by providing encryption, integrity and server authentication. It is the primary security mechanism for web applications.

The proposed architecture should use TLS 1.3 where supported and TLS 1.2 only when necessary for compatibility. Obsolete SSL and older TLS versions should be disabled.

A typical secure web connection is:

Client → HTTPS/TLS → Web Server

The server presents its X.509 certificate, the client validates the certificate and a secure cryptographic session is established.

TLS is used for websites, APIs, internal web applications and other sensitive application protocols.

4.7 PGP

Pretty Good Privacy can provide end-to-end email encryption and digital signatures. It is useful when sensitive email must remain protected from unauthorized parties throughout its communication path.

PGP provides confidentiality through encryption and authentication/integrity through digital signatures. It is particularly useful for selected sensitive communication with external business partners when a suitable PGP key-management process is available.

4.8 S/MIME

S/MIME provides email encryption and digital signatures using X.509 certificates. It is particularly suitable for enterprise environments where certificate management can be centrally controlled.

S/MIME can be used to digitally sign important corporate email and encrypt sensitive messages. A valid signature allows recipients to verify the sender and detect unauthorized modification.

4.9 Firewalls

Firewalls form the primary network access-control layer. They inspect network traffic according to defined security policies and allow or deny communication.

The organization should use perimeter firewalls between the Internet and enterprise network and internal firewalls between sensitive network segments.

The basic security principle is:

Deny by default → Allow only required communication

This reduces the attack surface and prevents unnecessary network exposure.

4.10 Access Control

Access control determines which authenticated users can access particular resources. The architecture uses role-based access control, access-control lists, least privilege and privileged-access restrictions.

For example, an ordinary employee should not have administrative access to database servers. A database administrator may access the database management system but should not automatically have access to unrelated financial or HR systems.

5. Design / Proposed Solution / Methodology

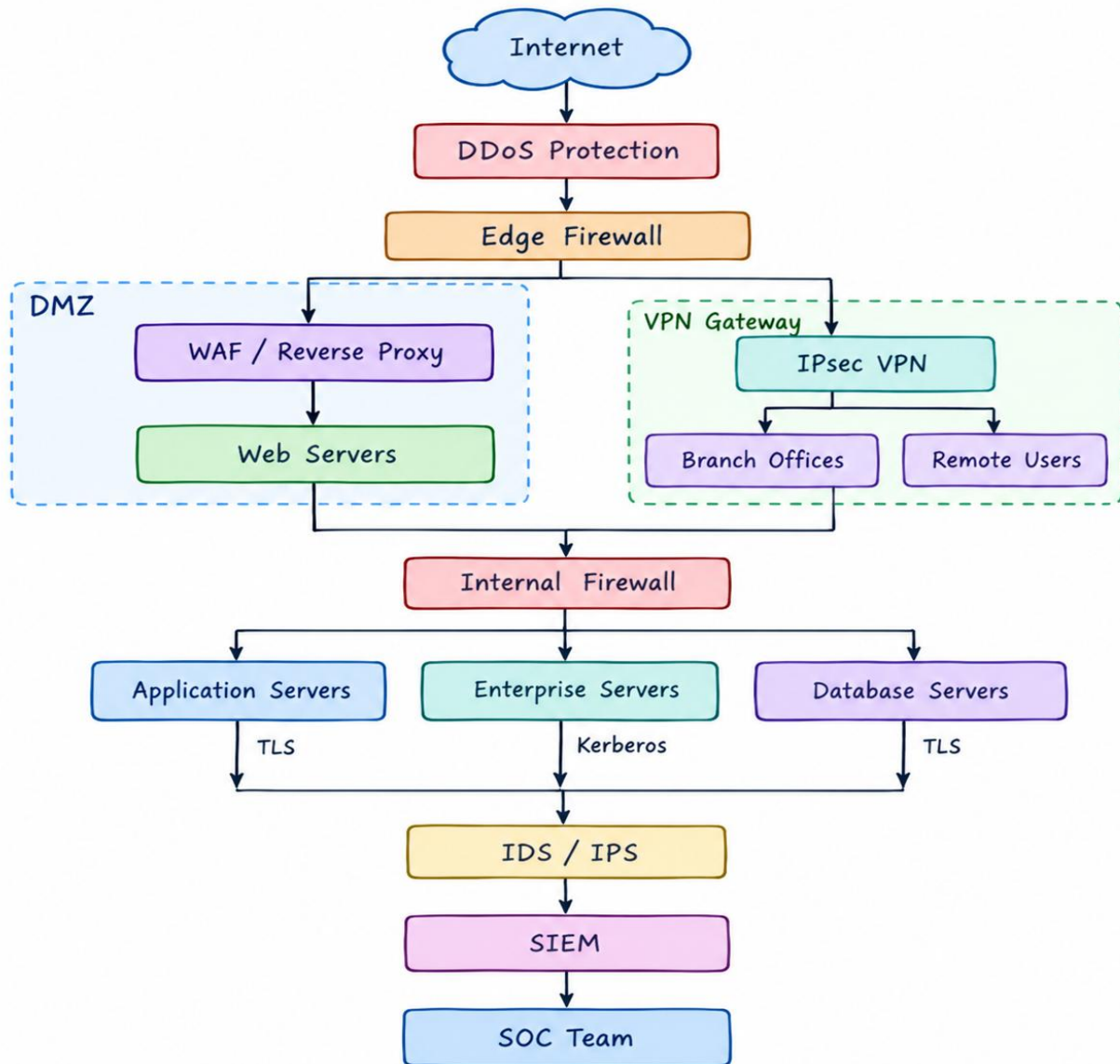
5.1 Proposed Architecture

The proposed architecture follows the defence-in-depth model. Instead of placing all security responsibility on the perimeter firewall, security controls are distributed across the Internet boundary, DMZ, internal network, application servers, databases, endpoints, users and monitoring infrastructure.

The Internet-facing portion of the architecture is separated from the internal enterprise network through a DMZ. Public web servers are placed in the DMZ so that they do not have unrestricted access to internal systems.

A firewall separates the DMZ from the internal network. Only required communication is permitted between the web servers and application servers. Database servers are placed in an even more restricted segment and should not be directly accessible from the Internet.

Branch offices connect through IPsec VPN tunnels. Remote users authenticate using strong authentication and MFA before accessing enterprise services.



6. Security Architecture for Web Services

Web applications are placed in a DMZ behind a Web Application Firewall. Incoming requests first pass through DDoS protection and the perimeter firewall. The WAF examines HTTP/HTTPS requests and can block suspicious application-layer activity.

TLS protects communication between clients and web servers. X.509 certificates allow clients to authenticate the server and establish trust. Application-level authentication and authorization are applied after the secure connection has been established.

The web servers should not communicate directly with database servers unless required. Application servers should act as an intermediate layer, reducing the possibility that a compromised web server can directly manipulate sensitive databases.

Rate limiting, secure session management, input validation, security headers and continuous vulnerability management should also be implemented.

7. Security Architecture for IP Communication

IPsec VPN is used to protect communication between branch offices and headquarters. The VPN gateway authenticates the remote endpoint and establishes an encrypted tunnel.

This prevents attackers on intermediate networks from reading or modifying the protected traffic. Anti-spoofing filtering and firewall rules are also applied to reduce the risk of forged source addresses.

The organization should maintain redundant VPN gateways for critical locations so that failure of one gateway does not completely interrupt communication.

8. Security Architecture for Email Services

Email is protected using multiple security layers. Incoming messages first pass through an email security gateway where spam, malicious attachments, suspicious URLs and other threats are analyzed.

Sender-authentication mechanisms such as SPF, DKIM and DMARC can reduce domain impersonation and email spoofing. Malware analysis and attachment sandboxing provide additional protection.

For sensitive business communication, S/MIME or PGP can provide message encryption and digital signatures. S/MIME is particularly appropriate for centrally managed corporate email because it integrates naturally with X.509-based certificate management.

9. Enterprise Authentication and Access Control

Kerberos is used for centralized authentication of internal enterprise users and services. Users authenticate through the organization's identity infrastructure and receive tickets that allow them to access permitted services.

For external-facing services, X.509 certificates and TLS provide server authentication. Multi-factor authentication should be applied to remote access, administrator accounts and other high-risk services.

Authorization is implemented using RBAC and least privilege. Users receive only the permissions necessary for their responsibilities. Administrative accounts should be separated from ordinary user accounts.

Privileged operations should be logged and monitored through the organization's security monitoring infrastructure.

10. Network Segmentation

Network segmentation is an important part of the proposed architecture. The organization should not operate all devices on one flat network.

The public web environment, application servers, enterprise servers, databases, management systems and user networks should be separated logically or physically.

If an attacker compromises a workstation, segmentation prevents the attacker from immediately reaching sensitive databases or administrative systems. Firewall rules between segments should allow only the minimum required communication.

11. Monitoring and Incident Response

All major security devices should send logs to a centralized SIEM. These devices include firewalls, VPN gateways, IDS/IPS sensors, servers, authentication systems, email gateways and endpoints.

The SIEM can correlate multiple events. For example, repeated failed logins followed by successful authentication from an unusual location may indicate compromised credentials.

When a serious event is detected, the security team can investigate the event, isolate affected systems, block malicious IP addresses or accounts, remove malware and restore affected systems from trusted backups.

12. Algorithm / Pseudocode / Flowchart

12.1 Secure Access Algorithm

Step 1: Receive a connection request.

Step 2: Check the request against firewall rules.

Step 3: If the request is unauthorized, reject it and record the event.

Step 4: Establish TLS or IPsec protection depending on the service.

Step 5: Validate certificates when certificate-based authentication is used.

Step 6: Authenticate the user or device.

Step 7: Perform MFA for sensitive access.

Step 8: Verify authorization using RBAC or ACL rules.

Step 9: Permit only authorized communication.

Step 10: Inspect traffic using IDS/IPS.

Step 11: Send relevant security events to the SIEM.

Step 12: If malicious activity is detected, block the traffic or isolate the affected system.

12.2 Pseudocode

```
BEGIN
```

```
  Receive connection request
```

```
  Check firewall policy
```

```
IF request is not allowed THEN
    Block request
    Record security event
    EXIT
END IF

IF service requires TLS THEN
    Establish TLS connection
    Validate X.509 certificate
    IF certificate is invalid THEN
        Reject connection
        Record security event
        EXIT
    END IF
END IF

END IF

Authenticate user/device

IF authentication fails THEN
    Deny access
    Record failed authentication
    EXIT
END IF

IF sensitive service THEN
    Perform MFA

    IF MFA fails THEN
        Deny access
        Record security event
        EXIT
    END IF
END IF

Check authorization

IF user is not authorized THEN
    Deny access
```



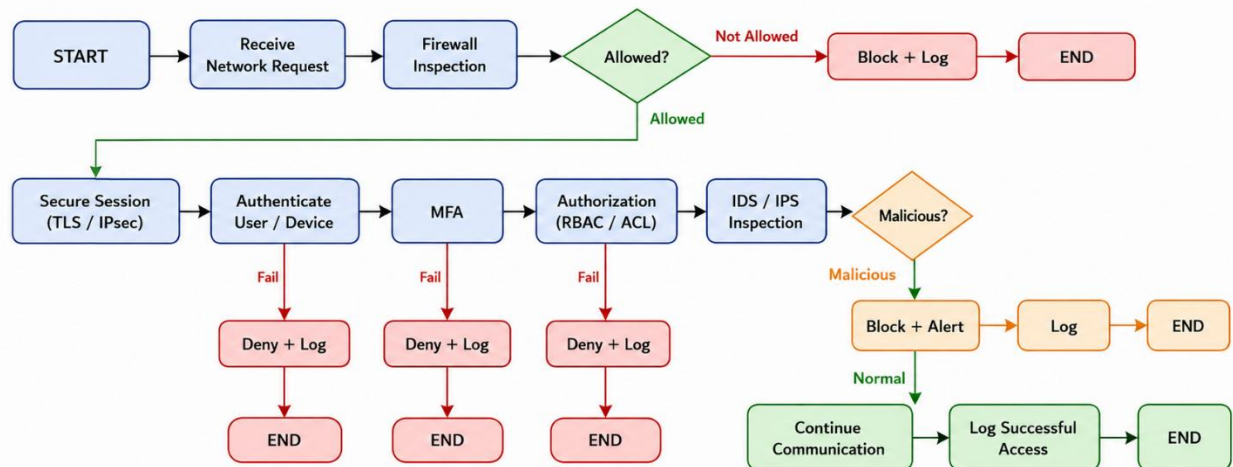
```

    Record event
    EXIT
END IF
Allow required service
Inspect traffic using IDS/IPS
IF malicious activity is detected THEN
    Block or isolate activity
    Send alert to SIEM
ELSE
    Continue communication
END IF

Record successful access
END

```

12.3 Flowchart



13. Implementation / Source Code and Environment / Tools Used

The proposed architecture can be implemented as a laboratory prototype using virtual machines and network-security software. GNS3 or EVE-NG can be used to construct the network topology.

A firewall such as pfSense or OPNsense can be deployed at the network boundary. Suricata or Snort can be used for IDS/IPS testing.

Wireshark can be used to inspect network packets and demonstrate the difference between protected and unprotected communication. OpenSSL can be used to generate and inspect certificates and demonstrate TLS functionality. StrongSwan can be used to create an IPsec VPN laboratory.

A Linux or Windows server can be used for enterprise services, while Kerberos can be configured for centralized authentication. A SIEM such as Wazuh can be used to collect and visualize security events.

For the practical demonstration, the environment can contain an attacker/test machine, perimeter firewall, DMZ web server, internal application server, database server, branch router, VPN gateway, IDS/IPS sensor and SIEM server.

The implementation should be performed only in an authorized laboratory environment. Security tests such as port scanning and attack simulation should be restricted to systems owned or explicitly authorized by the organization.

14. Example Hash Integrity Program

The following simple Python program demonstrates how a hash can identify data modification.

```
import hashlib

original_data = b"Confidential Enterprise Data"
original_hash = hashlib.sha256(original_data).hexdigest()
print("Original SHA-256:")
print(original_hash)

modified_data = b"Modified Enterprise Data"
modified_hash = hashlib.sha256(modified_data).hexdigest()
print("\nModified SHA-256:")
print(modified_hash)

if original_hash == modified_hash:
    print("\nData is unchanged")
```

else:

```
print("\nData modification detected")
```

The program generates a SHA-256 digest for the original data and another digest after modification. Since the data is different, the hashes should also be different. This demonstrates the basic principle of integrity verification.

15. Test Cases and Expected / Actual Results

Testing should be performed in a controlled environment. The following test cases provide a suitable validation plan.

Test	Expected Result	Actual Result
HTTPS connection	TLS connection successfully established	To be recorded
Invalid certificate	Connection rejected or certificate warning generated	To be recorded
Unauthorized port	Firewall blocks connection	To be recorded
IP spoofing test	Spoofed traffic filtered or detected	To be recorded
Packet capture of HTTPS	Application content remains encrypted	To be recorded
MITM with invalid certificate	Certificate validation prevents trusted connection	To be recorded
Valid Kerberos login	Authentication succeeds	To be recorded
Invalid credentials	Authentication rejected	To be recorded
Unauthorized resource access	RBAC/ACL blocks access	To be recorded
Malicious attachment	Email/endpoint security detects or blocks it	To be recorded

16. Execution Screenshots / Outputs

The final practical report should include screenshots from the actual implementation.

The first screenshot should show the complete network topology, including the Internet, firewall, DMZ, web server, internal network, branch network, VPN gateway, IDS/IPS and SIEM.

The second screenshot should demonstrate a successful HTTPS connection and display the X.509 certificate used by the web server.

The third screenshot should show the active IPsec tunnel between a branch network and the headquarters network.

The fourth screenshot should show Wireshark capturing encrypted HTTPS or IPsec traffic. The purpose is to demonstrate that sensitive application information cannot simply be read from captured packets.

The fifth screenshot should show a firewall log containing a blocked unauthorized connection.

The sixth screenshot should show an IDS/IPS alert generated by an authorized security test such as a controlled port scan.

The seventh screenshot should demonstrate successful Kerberos authentication or a valid authentication ticket.

The eighth screenshot should demonstrate an S/MIME or PGP signed/encrypted email.

The ninth screenshot should show SIEM events collected from the firewall, IDS/IPS, server and authentication systems.

These screenshots provide practical evidence that the proposed architecture is not only theoretical but can be implemented and validated.

Source code:

```
print("=== ENTERPRISE NETWORK SECURITY ===")

# 1. Receive Request
print("\n1. Network Request Received")

# 2. Firewall
port = int(input("Enter Port (80/443): "))
if port not in [80, 443]:
    print("Firewall: BLOCKED")
    print("ACCESS DENIED")
    exit()
print("Firewall: ALLOWED")

# 3. Secure Session
print("\n2. Secure Session")
print("TLS / IPsec: ESTABLISHED")

# 4. Authentication
username = input("\nEnter Username: ")
password = input("Enter Password: ")
if username != "admin" or password != "admin123":
    print("Authentication: FAILED")
    print("ACCESS DENIED")
    exit()
print("Authentication: SUCCESS")

# 5. MFA
otp = input("Enter OTP: ")
if otp != "123456":
    print("MFA: FAILED")
    print("ACCESS DENIED")
```

```

        exit()

print("MFA: VERIFIED")

# 6. Authorization

resource = input("Enter Resource (WEB/EMAIL/DATABASE):")
resource = resource.upper()

if resource not in ["WEB", "EMAIL", "DATABASE"]:

    print("Authorization: DENIED")

    print("ACCESS DENIED")

    exit()

print("Authorization: ALLOWED")

# 7. IDS / IPS

print("\n3. IDS / IPS")

print("1. Normal Traffic")

print("2. Malicious Activity")

choice = int(input("Enter choice: "))

if choice == 2:

    print("Malicious Activity Detected")

    print("Block / Isolate + Alert")

    print("Log Event")

    print("ACCESS DENIED")

    exit(

print("Normal Traffic")

print("Communication Continued")

print("Successful Access Logged")

print("\n=== ACCESS GRANTED ===")

```

```
Output

=====
ENTERPRISE NETWORK SECURITY SYSTEM
=====

Enter Username: admin
Enter Password: Admin@123

--- KERBEROS AUTHENTICATION ---
Authentication: SUCCESS
Kerberos Ticket: GENERATED

--- FIREWALL ---
Enter Destination Port: 443
Firewall: ALLOWED

--- SECURE COMMUNICATION ---
1. TLS
2. IPsec
Enter choice: 1
TLS: SECURE CONNECTION ESTABLISHED

--- X.509 CERTIFICATE ---
Enter 1 for Valid Certificate: 1
Certificate: VALID

--- MULTI-FACTOR AUTHENTICATION ---
Enter OTP: 123456
MFA: VERIFIED

--- ACCESS CONTROL ---
Enter Resource (WEB/EMAIL/DATABASE): DATABASE
Authorization: ALLOWED

--- IDS / IPS ---
1. Normal Traffic
2. Port Scan
3. MITM Attack
4. DoS Attack
5. IP Spoofing
Enter Network Activity: 1
IDS/IPS: NORMAL TRAFFIC

=====
ACCESS GRANTED
=====
User       : admin
Kerberos   : SUCCESS
Firewall   : ALLOWED
Secure Connection : ESTABLISHED
X.509 Certificate : VALID
MFA        : VERIFIED
Authorization : ALLOWED
IDS/IPS     : NORMAL

Enterprise system is secure.
```

17. Results and Validation

The proposed architecture provides multiple layers of protection. TLS protects application communication, IPsec protects network communication, Kerberos provides centralized authentication, certificates establish trusted identities, digital signatures protect integrity and non-

repudiation, firewalls restrict network access, IDS/IPS detects malicious activity and endpoint security reduces malware risk.

The validation process should compare the system before and after applying the security controls. For example, an HTTP connection can be compared with HTTPS to demonstrate the effect of encryption. A normal network connection can be compared with an IPsec-protected connection to demonstrate VPN protection.

Similarly, a modified file can be processed using SHA-256 before and after modification. The different hash values demonstrate that unauthorized changes can be detected.

The main performance measurements should include latency, throughput, packet loss, TLS handshake time, VPN overhead, authentication time, IDS detection rate and false-positive rate. These measurements should be obtained from the actual laboratory environment rather than being artificially generated.

18. Attack Scenario Evaluation

18.1 Man-in-the-Middle Attack

In a man-in-the-middle attack, an attacker attempts to position themselves between two communicating parties and intercept or modify their communication.

The proposed architecture mitigates this threat using TLS, X.509 certificates, certificate validation and IPsec authentication. When a client connects to a secure web server, the server presents its certificate. The client validates the certificate before trusting the server.

If the attacker presents an invalid certificate, certificate validation should prevent the connection from being treated as a trusted connection. IPsec also provides authenticated communication between VPN endpoints.

Therefore, the proposed architecture provides strong protection against typical network-level MITM attacks, assuming certificate validation and cryptographic configurations are correctly implemented.

18.2 IP Spoofing

IP spoofing occurs when an attacker attempts to make malicious traffic appear to originate from a different IP address.

The architecture mitigates this threat using ingress and egress filtering, stateful firewall rules, network segmentation, IDS/IPS and authenticated IPsec tunnels.

Even if an attacker attempts to forge a source address, the firewall can reject traffic that violates expected network policies. IPsec also ensures that protected VPN communication is authenticated.

Therefore, IP spoofing is significantly reduced, although spoofing controls must be applied consistently throughout the network.

18.3 Packet Sniffing

Packet sniffing involves capturing network traffic to obtain sensitive information.

Without encryption, an attacker who captures network packets may be able to obtain usernames, passwords or business information. TLS and IPsec prevent this by encrypting protected communication.

A captured HTTPS packet may reveal metadata such as endpoints and traffic timing, but the protected application content should not be directly readable.

Therefore, encryption provides strong protection against the disclosure of sensitive application data through packet sniffing.

18.4 Phishing

Phishing attempts to trick users into providing credentials or executing malicious content.

The proposed architecture uses email security gateways, spam filtering, URL analysis, malware scanning, attachment sandboxing, SPF, DKIM and DMARC. S/MIME can additionally help recipients verify messages that are digitally signed by trusted organizational identities.

However, technology alone cannot eliminate phishing because attackers can exploit human behaviour. Security awareness training, simulated phishing exercises and clear reporting procedures are therefore necessary.

18.5 Unauthorized Access

Unauthorized access occurs when an individual gains access to a resource without sufficient privileges.

The architecture addresses this using centralized authentication, Kerberos, MFA, RBAC, ACLs and least privilege.

Authentication verifies who the user is, while authorization determines what that user is allowed to access. This distinction is important because a legitimate employee should not automatically have access to every enterprise system.

Therefore, unauthorized access is strongly reduced through the combination of identity and access-control mechanisms.

18.6 Malware Propagation

Malware propagation occurs when malicious software spreads from one system to another.

The proposed architecture uses email scanning, endpoint protection, EDR, IDS/IPS, network segmentation, application control, patch management and least privilege.

If one workstation becomes infected, segmentation can prevent unrestricted communication with critical servers. IDS/IPS can identify suspicious network behaviour, while endpoint security can isolate the infected machine.

Therefore, the architecture significantly limits malware propagation.

18.7 Data Tampering

Data tampering involves unauthorized modification of information.

Hash functions can detect changes by comparing the current digest with the expected digest. HMAC provides integrity and authentication when a shared secret is available. TLS and IPsec

provide integrity protection for protected communication. Digital signatures additionally provide strong origin authentication and non-repudiation.

Therefore, multiple mechanisms are available depending on the required security property.

18.8 Denial-of-Service Attack

A denial-of-service attack attempts to make a service unavailable by consuming resources.

The architecture uses DDoS protection, firewall filtering, rate limiting, load balancing, redundant infrastructure and IDS/IPS.

For public web services, traffic can be distributed across multiple servers. Suspicious traffic can be filtered before reaching application servers.

However, no architecture can guarantee complete protection against every DDoS attack. Very large attacks may exceed available network capacity, so upstream DDoS mitigation and sufficient service redundancy are also important.

19. Analysis, Comparison, Trade-offs and Justification

Mechanism	Main Security Purpose	Major Advantage	Main Limitation
SHA-256/SHA-384	Integrity	Fast and scalable	Does not provide confidentiality
Digital Signature	Integrity, authentication, non-repudiation	Strong proof of origin	Requires key management
Kerberos	Authentication	Centralized enterprise authentication	Requires reliable identity infrastructure
X.509	Identity and trust	Strong certificate-based authentication	Certificate lifecycle is complex
TLS	Application security	Protects web app	Requires correct certi

20. Broader Considerations / SDG Relevance

The proposed architecture supports broader organizational resilience and responsible digital infrastructure.

It contributes to **SDG 9 – Industry, Innovation and Infrastructure** by improving the resilience and security of digital infrastructure. Secure communication allows organizations to operate digital services reliably across geographical locations.

It also supports **SDG 8 – Decent Work and Economic Growth** because protecting enterprise systems reduces downtime, financial losses and disruption caused by cyberattacks.

The architecture also relates to **SDG 16 – Peace, Justice and Strong Institutions** because strong authentication, access control, accountability, audit logging and secure information exchange support trustworthy digital operations.

Beyond the SDGs, the organization must consider privacy, regulatory compliance, supply-chain security, insider threats, cloud security, third-party risks, business continuity and disaster recovery. Security policies should be reviewed regularly because threats and technologies continuously change.

21. Conclusion, Limitations and Possible Improvements

21.1 Conclusion

The proposed enterprise network security architecture provides a comprehensive solution for protecting a multinational organization's distributed digital infrastructure. It combines cryptographic mechanisms, digital signatures, Kerberos, X.509 certificates, TLS, IPsec, PGP, S/MIME, firewalls, access controls, IDS/IPS and malware protection into a unified defence-in-depth architecture.

TLS and X.509 certificates protect web and application communication. IPsec provides secure communication between branches and other network locations. Kerberos provides centralized enterprise authentication, while MFA strengthens protection against compromised credentials. Digital signatures provide integrity, authentication and non-repudiation.

Firewalls and segmentation restrict unauthorized communication, while IDS/IPS detects suspicious network activity. Email security mechanisms reduce phishing and malware risks, and endpoint protection limits malware propagation.

The evaluation shows that the proposed architecture can significantly reduce the risk and impact of man-in-the-middle attacks, IP spoofing, packet sniffing, phishing, unauthorized access, malware propagation, data tampering and denial-of-service attacks. The architecture is therefore suitable for establishing a secure, reliable, scalable and trusted enterprise communication infrastructure.

21.2 Limitations

The main limitation is that implementing multiple security layers increases cost and complexity. Encryption, IDS/IPS and other inspection mechanisms may also introduce processing overhead.

Legacy systems may not support modern protocols and may require upgrades or compensating controls. Certificate and key management can become difficult as the organization grows.

IDS/IPS systems may generate false positives, and security administrators must continuously tune detection rules. DDoS protection can reduce the impact of attacks but cannot guarantee complete immunity from extremely large attacks.

Human behaviour remains another limitation because phishing and social engineering can bypass technical controls.

21.3 Possible Improvements

The architecture can be improved by adopting Zero Trust principles, passwordless authentication, stronger hardware-backed credentials, micro-segmentation, automated certificate management, security orchestration and automated response.

AI-assisted security analytics can improve detection of abnormal behaviour. XDR can provide broader visibility across endpoints, networks, email and cloud environments.

The organization should also develop a migration plan for post-quantum cryptography because long-lived sensitive information may require protection against future cryptographic threats.

Regular vulnerability assessments, penetration testing, security-awareness training, disaster-recovery exercises and incident-response simulations should be conducted to maintain the effectiveness of the architecture.

22. Individual Contribution of Group Members

The project work can be divided among group members according to different areas of the proposed security architecture. One member can focus on problem analysis and security requirements, another can design the network topology and firewall architecture, while another can study cryptographic mechanisms, TLS and certificates.

Another member can focus on Kerberos, authentication and access control. A further member can work on IDS/IPS, malware protection and attack-scenario analysis. Testing, performance evaluation, documentation and final report preparation can be distributed among the members.

Each member should understand the complete architecture even if individual members are responsible for specific modules. The final design should be reviewed collectively so that the security controls operate as an integrated system rather than as isolated mechanisms.

23. References

- [1] E. Rescorla, “The Transport Layer Security (TLS) Protocol Version 1.3,” RFC 8446, Internet Engineering Task Force, Aug. 2018.
- [2] S. Kent and K. Seo, “Security Architecture for the Internet Protocol,” RFC 4301, Internet Engineering Task Force, Dec. 2005.
- [3] E. Barker, Q. Dang, S. Frankel, K. Scarfone, and P. Wouters, “Guide to IPsec VPNs,” NIST Special Publication 800-77 Rev. 1, National Institute of Standards and Technology, Jun. 2020.
- [4] K. McKay and D. Cooper, “Guidelines for the Selection, Configuration, and Use of Transport Layer Security (TLS) Implementations,” NIST Special Publication 800-52 Rev. 2, National Institute of Standards and Technology, Aug. 2019.
- [5] D. Cooper, S. Santesson, S. Farrell, S. Boeyen, R. Housley, and W. Polk, “Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile,” RFC 5280, Internet Engineering Task Force, May 2008.
- [6] C. Neuman, T. Yu, S. Hartman, and K. Raeburn, “The Kerberos Network Authentication Service (V5),” RFC 4120, Internet Engineering Task Force, Jul. 2005.
- [7] D. Eastlake 3rd and P. Jones, “US Secure Hash Algorithm 1 (SHA1),” RFC 3174, Internet Engineering Task Force, Sep. 2001.
- [8] E. Barker and J. Roginsky, “Transitioning the Use of Cryptographic Algorithms and Key Lengths,” NIST Special Publication 800-131A Rev. 2, National Institute of Standards and Technology, Mar. 2019.
- [9] E. Barker, “Recommendation for Key Management: Part 1 – General,” NIST Special Publication 800-57 Part 1 Rev. 5, National Institute of Standards and Technology, May 2020.
- [10] P. Hoffman and B. Ramsdell, “S/MIME Version 3.2 Message Specification,” RFC 5751, Internet Engineering Task Force, Jan. 2010.
- [11] J. Callas, L. Donnerhake, H. Finney, D. Shaw, and R. Thayer, “OpenPGP Message Format,” RFC 4880, Internet Engineering Task Force, Nov. 2007.

- [12] K. Scarfone and P. Mell, “Guide to Intrusion Detection and Prevention Systems (IDPS),” NIST Special Publication 800-94, National Institute of Standards and Technology, Feb. 2007.
- [13] K. Scarfone, M. Souppaya, A. Cody, and A. Orebaugh, “Technical Guide to Information Security Testing and Assessment,” NIST Special Publication 800-115, National Institute of Standards and Technology, Sep. 2008.
- [14] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Rev. 2, National Institute of Standards and Technology, Aug. 2012.
- [15] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, Aug. 2020.
- [16] NIST, “Security and Privacy Controls for Information Systems and Organizations,” NIST Special Publication 800-53 Rev. 5, National Institute of Standards and Technology, Sep. 2020.
- [17] NIST, “Cybersecurity Framework (CSF) 2.0,” National Institute of Standards and Technology, Gaithersburg, MD, USA, Feb. 2024.
- [18] W. Stallings, *Cryptography and Network Security: Principles and Practice*, 8th ed. Hoboken, NJ, USA: Pearson, 2020.
- [19] W. Stallings, *Network Security Essentials: Applications and Standards*, 6th ed. Boston, MA, USA: Pearson, 2017.
- [20] M. Bishop, *Computer Security: Art and Science*, 2nd ed. Boston, MA, USA: Addison-Wesley, 2019.

24. One-Page Individual Reflection

Individual Reflection on Learning and Personal Development

This assignment provided me with a better understanding of how different network security technologies can be combined to protect a large enterprise network. Before studying the complete architecture, I considered mechanisms such as firewalls, encryption, authentication and IDS/IPS as separate security technologies. Through this assignment, I understood that a real enterprise requires several layers of security because no single mechanism can protect an organization against every type of cyberattack. I developed a clear understanding of cryptographic hash functions, digital signatures, Kerberos, X.509 certificates, TLS, IPsec, PGP and S/MIME. I learned that these mechanisms have different purposes. Hash functions are mainly used for integrity verification, digital signatures provide integrity, authentication and non-repudiation, TLS protects application communication, and IPsec protects network-layer communication. Kerberos provides centralized authentication, while X.509 certificates establish trust between communicating systems.

The attack analysis helped me understand the practical importance of these concepts. By studying man-in-the-middle attacks, IP spoofing, packet sniffing, phishing, unauthorized access, malware propagation, data tampering and denial-of-service attacks, I learned how individual security controls work together. I also learned that network security involves more than implementing technical tools. Proper access policies, least privilege, security awareness, patch management, centralized logging, incident response and backup procedures are equally important. A technically strong security architecture can still fail if users are not trained or if security devices are incorrectly configured.

Overall, this assignment strengthened my technical knowledge and increased my understanding of enterprise cybersecurity. I learned that a secure network is not created by a single firewall or encryption mechanism. It requires coordinated protection involving cryptography, authentication, authorization, secure communication, network segmentation, monitoring, malware protection, incident response and continuous improvement. This knowledge will be valuable for designing secure and resilient enterprise systems in future projects and professional environments.